



SentinelScan

A SAFER WEB TOMORROW

SentinelScan

Passive web security scanner

A passive-first, evidence-driven security assessment platform that transforms fragmented external visibility into structured, actionable security posture with built-in scanner-side safety, CVE and lifecycle intelligence, and remediation-ready output.

The Problem: No clear view of Security Risks

Modern web applications face risks from misconfigured HTTP headers, outdated TLS, exposed files, outdated technologies, and unsecured application surfaces. Existing assessments are often manual, fragmented, or intrusive, making it difficult to get a clear view of overall security.

DNS

Records, subdomains, and zone exposure assessed in isolation

TLS

Certificate validity, chain, and protocol gaps unchecked

HTTP Headers

Missing or misconfigured security headers invisible to standard tooling

Cookies

Attribute gaps across session management

Technologies

Stack fingerprinting without version or CVE correlation

Content

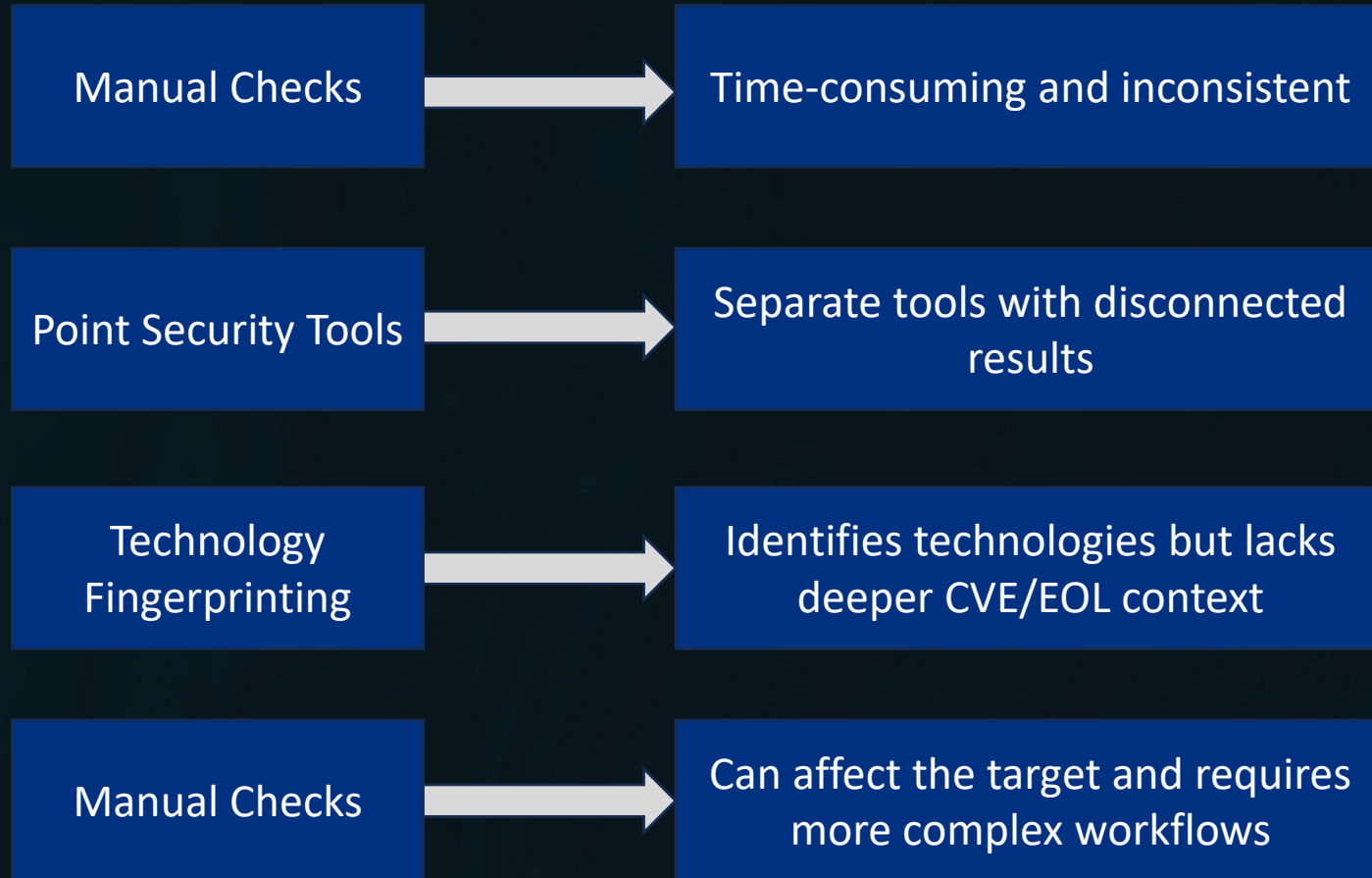
Information disclosure and error leakage undetected

App Indicators

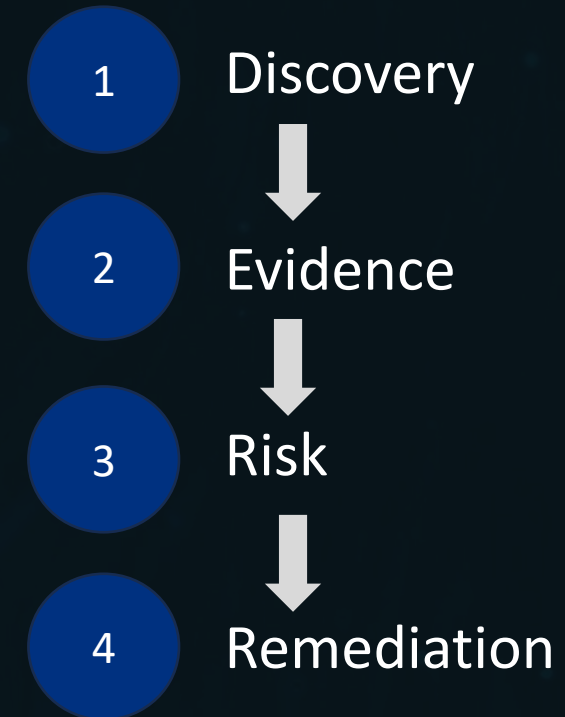
OWASP signals and application-level exposure uncorrelated

Research & Existing Solutions

Current approaches solve individual security checks, but leave gaps between discovery and remediation.



THE PROBLEM GAP



Existing approaches often handle these steps separately. SentinelScan brings them together in one workflow.

The Solution: SentinelScan

One unified security assessment pipeline — from a target URL to clear findings, risk scores, and practical recommendations.

Target URL Input validation and safety checks	Safety Validation SSRF guard, IP pinning, redirect re-validation
External Security Checks DNS, TLS, HTTP, cookies, content	Safe Security Checks Non-destructive, boundary-respecting checks
Technology & Vulnerability Intelligence Version extraction and lifecycle correlation	OWASP Top 10:2025 A01–A10 assessment coverage
Evidence & Scoring 0–100 Security Posture Score	Actionable Reports Web, JSON, Executive PDF, Technical PDF

Why SentinelScan Is Different

One workflow connecting security checks, evidence, intelligence, risk and remediation.



Safe by Design

Non-destructive by design. Assessment stays within the external boundary — no intrusive exploitation, no side effects on the target.



Evidence-Based

Findings are backed by observable evidence, with **NOT_VERIFIABLE** used when evidence is insufficient.



CVE + EOL Intelligence

Technology → Version → NIST NVD → CVE / CVSS → EOL correlation. 23 technologies fingerprinted, 10 with version extraction.



Scanner Security

Built-in SSRF protection, DNS rebinding defense, IP pinning, and TOCTOU mitigation. The scanner itself is hardened.

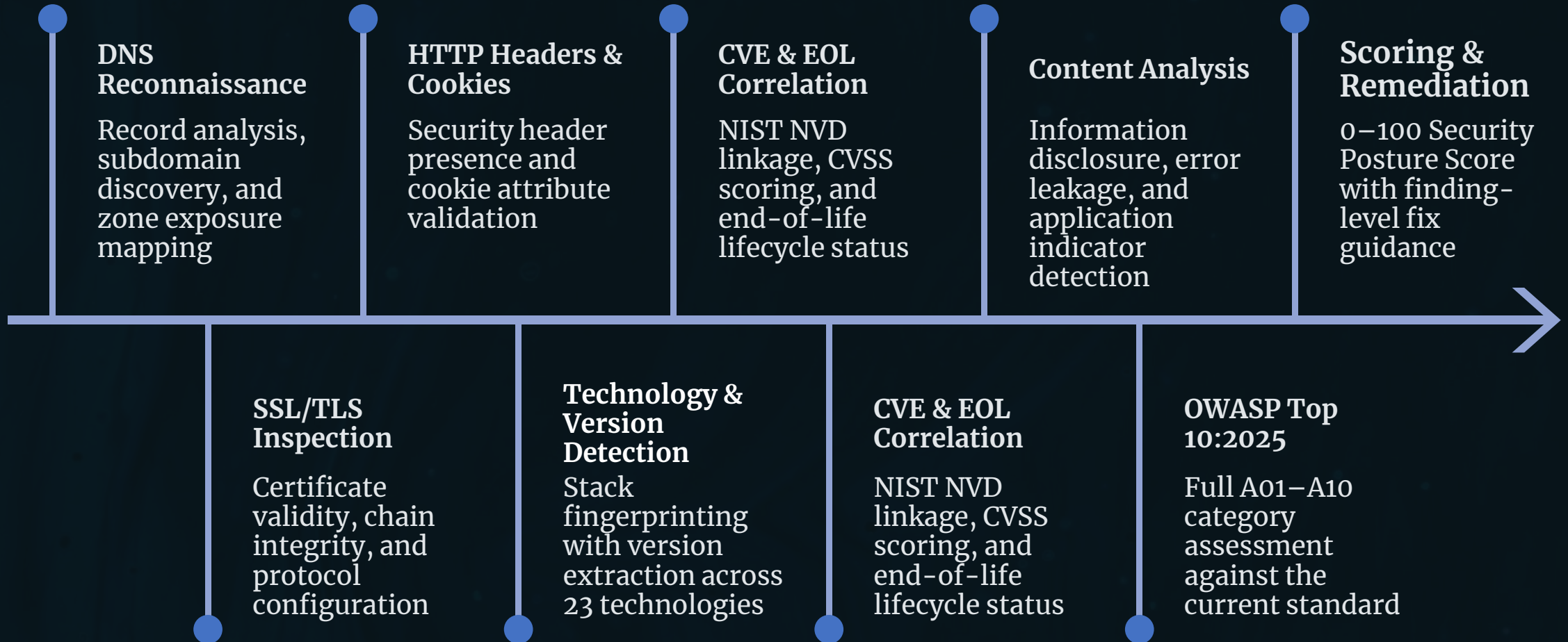


Built for Remediation

Finding-level remediation steps with configuration snippets for Nginx, Apache, Express/Helmet, and Caddy — not just raw vulnerability output.

The 8-Stage Assessment Engine

SentinelScan processes each target through eight stages, from DNS discovery to risk scoring and remediation.



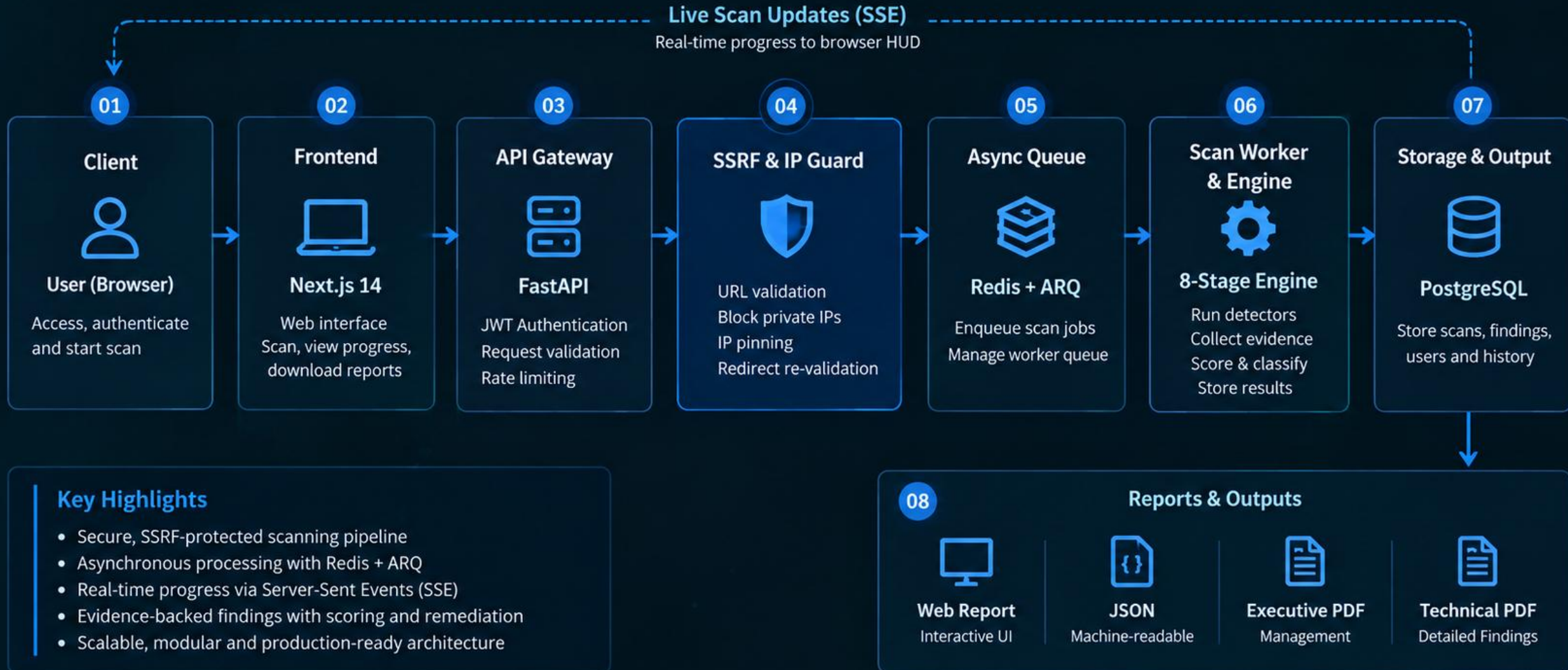
System Architecture

A secure, asynchronous pipeline that validates every target before it reaches the assessment engine.



SentinelScan

Observe | Assess | Strengthen



Who Secures the Security Scanner?

SentinelScan uses a fail-closed, multi-layer defense against SSRF, DNS rebinding, and TOCTOU attacks.



SSRF Defense

Multi-stage URL and IP validation before any outbound connection is opened

DNS Rebinding / TOCTOU

IP pinning and redirect re-validation eliminate time-of-check-to-time-of-use gaps

IPv4 / IPv6 / NAT64

Full dual-stack awareness with NAT64 translation handling — no bypass vectors

Security Intelligence + Evidence + Scoring

SentinelScan correlates technology fingerprints with NIST NVD data to surface CVE and end-of-life status — then classifies, proves, and prioritizes every finding against OWASP Top 10:2025.

Technology → CVE → EOL Pipeline

Technology Detection

23 technologies fingerprinted across the external surface

Version Extraction

10 technologies with precise version identification for CVE matching

NIST NVD Correlation

CVE and CVSS linkage via verified NVD data

Lifecycle / EOL Status

End-of-life flagging for technologies no longer receiving security updates

Classify · Prove · Prioritize

CLASSIFY

OWASP Top 10:2025 A01–A10 category mapping

PROVE

Observable, verifiable evidence — or explicit NOT_VERIFIABLE declaration

PRIORITIZE

0–100 Security Posture Score with weighted risk aggregation

Key Features & Capabilities

Security Assessment

- **DNS Analysis** — Records & domain exposure
- **TLS / SSL** — Certificates & protocols
- **Headers & Cookies** — Security configuration checks
- **Content Analysis** — Exposed information & files

Risk & Evidence

- **OWASP Top 10:2025** — A01–A10 coverage
- **Evidence-Backed Findings** — Observable evidence
- **Severity & Confidence** — Structured risk classification
- **Security Posture Score** — 0–100
- **NOT_VERIFIABLE** — Explicit assessment boundary

Security Intelligence

- **Technology Detection** — 23 technologies
- **Version Extraction** — 10 technologies
- **CVE Correlation** — NIST NVD intelligence
- **Lifecycle Intelligence** — EOL status

Platform Capabilities

- **Authentication & Authorization** — Secure access
- **Rate Limiting** — API protection
- **Live SSE HUD** — Real-time progress
- **Multi-Format Reports** — Web, JSON & PDF
- **Finding-Level Remediation** — Practical fixes

Working Product: From Finding to Fix

Every finding connects evidence to remediation with practical fixes and references.



One Scan. Multiple Outputs

Interactive Web Report

Live SSE HUD with real-time scan progress

Executive PDF

Management-ready risk summary

Machine-Readable JSON

CI/CD, automation, and SIEM integration

Technical PDF

Developer-grade finding detail and remediation

CHALLENGES & LIMITATIONS

SentinelScan balances detection depth, scanner safety, and what can be proven from external evidence.

CHALLENGES

SSRF & DNS
Rebinding

Async Scan
Coordination

CVE Version
Accuracy

Detection
Depth vs.
Safety

LIMITATIONS

External
Observation

No
Authenticated
Workflows

Limited
Detection
Depth

CVE
Accuracy

If it cannot be proven externally, SentinelScan does not assume it — it reports the boundary.

Conclusion

SentinelScan transforms external security observations into evidence-backed security posture, helping teams understand risk, prioritize findings, and take action.

Future Scope

- Expanded technology/security intelligence
- Broader application/API coverage
- Authenticated assessment workflows
- Additional integrations
- Expanded compliance/standards coverage
- Further scalability and assessment capabilities

Team AttackSurface

Team ID : 28



Nandini Vora
202302626010143



Dhwani Yadav
202302626010146

Thank You